FICHE 6 - SÉCURISER LES POSTES DE TRAVAIL

Prévenir les accès frauduleux, l'exécution de programmes malveillants (ex. : virus) ou la prise de contrôle à distance, notamment via Internet.

Les risques d'intrusion dans les systèmes informatiques sont multiples et les postes de travail constituent un des principaux points d'entrée.

Les précautions élémentaires

- Prévoir un mécanisme de **verrouillage automatique de session** en cas de non-utilisation du poste pendant un temps donné.
- Installer un **pare-feu** (« *firewall* ») logiciel sur le poste et limiter l'ouverture des ports de communication à ceux strictement nécessaires au bon fonctionnement des applications installées sur le poste de travail.
- Utiliser des **antivirus régulièrement mis à jour.**
- **Déployer les mises à jour de sécurité au plus tôt**, le cas échéant après les avoir testées. Les mises à jour venant corriger des failles critiques publiques doivent d'autant plus être installées sans délais.
- Limiter les droits des utilisateurs au strict minimum en fonction de leurs besoins sur les postes de travail.
- **Favoriser le stockage des données des utilisateurs sur un espace de stockage régulièrement sauvegardé accessible via le réseau interne de l'organisme** plutôt que sur les postes de travail. Dans le cas où des données sont stockées localement, fournir des moyens de synchronisation ou de sauvegarde aux utilisateurs et les former à leur utilisation.
- **Effacer de façon sécurisée les données présentes sur un poste préalablement à sa réaffectation** à une autre personne.
- Pour les **supports amovibles** (ex. : clés USB, disques durs externes) :
  - sensibiliser les utilisateurs aux risques liés à l'utilisation de supports amovibles, en particulier s'ils proviennent de l'extérieur ;
  - **limiter la connexion de supports amovibles** à l'indispensable ;
  - désactiver l'exécution automatique (« *autorun* ») depuis les supports amovibles.
- Pour l'**assistance sur les postes de travail** :
  - les outils d'administration à distance doivent **recueillir l'accord** de l'utilisateur avant toute intervention sur son poste (ex. : en répondant à un message s'affichant à l'écran, à l'occasion d'un rendez-vous accepté) ;
  - l'utilisateur doit également pouvoir **constater si la prise de main à distance est en cours** et quand elle se termine (ex. : affichage d'un message à l'écran).

Ce qu'il ne faut pas faire

- Utiliser des systèmes d'exploitation dont le support n'est plus assuré par l'éditeur.
- Donner des privilèges, en local comme sur le réseau, aux utilisateurs n'ayant pas une fonction le justifiant (ex. : administrateurs).